

Page title →What's Changing in AI Governance

AI is moving faster than the rules meant to govern it — and the rules themselves are moving faster than most organizations can track. In the past year alone, NIST has drafted an AI-specific cybersecurity framework, opened a formal inquiry into securing autonomous agents, launched a standing initiative to standardize agent security, and published a mathematical proof that static defenses can never fully hold. OWASP released the first risk framework built for agentic systems rather than chatbots. Independent research keeps confirming the same underlying problem: employees are adopting AI faster than anyone is tracking it.

This page follows those developments as they happen — each one explained in plain language, sourced directly, and read together as a single, evolving picture of where AI governance is headed next.

A running log of the developments reshaping how organizations are expected to secure, monitor, and govern the AI tools running inside their walls.

NIST Opens the Door to an AI-Specific Cybersecurity Framework

In mid-December 2025, after a yearlong effort that pulled in more than 6,500 contributors, the National Institute of Standards and Technology released the preliminary draft of its Cybersecurity Framework Profile for Artificial Intelligence — informally, the "Cyber AI Profile." Built as a companion to the widely adopted CSF 2.0, the profile is organized around three overlapping ideas: securing the AI systems an organization runs, using AI to strengthen its own defenses, and blocking the new wave of AI-enabled attacks aimed at it.

It's a notable moment because it's the first time NIST has tried to formally translate its general-purpose cybersecurity language into something built specifically for AI systems — rather than asking security teams to awkwardly retrofit older frameworks onto a technology that didn't exist when those frameworks were written. Public comment closed January 30, 2026, with a fuller release expected later in the year.

What the draft doesn't solve, at least not yet, is the more basic question sitting underneath it: an organization can't secure AI systems it doesn't know it has. A framework for how to secure AI is only useful once there's a reliable inventory of what AI is actually running.

Source: [NIST, "Draft NIST Guidelines Rethink Cybersecurity for the AI Era"](#)

OWASP Publishes the First Top 10 Built for Agents, Not Just Models

Two days before NIST's draft dropped, the OWASP GenAI Security Project released something the industry had been asking for: a Top 10 list built specifically for agentic applications, not the chatbot-era LLM risks the original OWASP Top 10 for LLMs already covered. Peer-reviewed by more than 100 security researchers and practitioners, the list catalogs risks that only exist once an AI system stops just answering questions and starts taking actions — calling APIs, executing code, moving files, delegating to other agents.

The list opens with Agent Goal Hijack, where an attacker manipulates an agent's objective by hiding instructions inside content the agent processes — a poisoned email, a malicious calendar invite, a compromised document pulled into a retrieval pipeline. It continues through tool misuse, identity and privilege abuse, memory and context poisoning, cascading failures across multi-agent systems, and what OWASP calls "rogue agents" — systems whose behavior has quietly drifted from its intended purpose while still looking authorized on paper. The project also introduced a new design principle for builders: least agency, the idea that an agent should be granted only the minimum autonomy its task actually requires.

The throughline across all ten risks is that none of them show up in a single prompt or a single response. They emerge across a chain of decisions, tool calls, and delegated actions — which means catching them requires visibility into that whole chain, not just a snapshot of any one exchange.

Source: [OWASP GenAI Security Project, "OWASP Top 10 for Agentic Applications for 2026"](#)

Washington Starts Asking How to Secure AI Agents Specifically

By January 2026, the conversation had moved from "how do we secure AI models" to "how do we secure AI agents" at the federal level. NIST's Center for AI Standards and Innovation (CAISI) published a formal Request for Information — Federal Register docket NIST-2025-0035 — asking industry, academia, and the security community how existing cybersecurity practices hold up against risks unique to autonomous systems: indirect prompt injection buried in retrieved documents, data poisoning, and models that behave badly not because they were hacked, but because their objectives were subtly gamed or misaligned from the start.

It was the first formal U.S. government effort scoped specifically to agent security rather than AI security in general, and the response was significant — organizations ranging from the OpenID Foundation to commercial AI providers submitted formal comments before the March 9 deadline.

Source: [NIST, "CAISI Issues Request for Information About Securing AI Agent Systems"](#)

CAISI Turns the RFI Into a Standing Initiative

The RFI wasn't a one-off. In February, CAISI folded what it had learned into a formal, ongoing program: the AI Agent Standards Initiative. It rests on three pillars — pushing industry-led technical standards for agent security and identity, supporting open-source protocol development (including work on things like the Model Context Protocol), and funding deeper research into how agents can be verified, monitored, and trusted at scale.

NIST framed the stakes plainly: agents can already work autonomously for hours, write and debug code, manage someone's email and calendar, and make purchases on their behalf. The productivity upside is real, but so is the fact that almost none of the identity management, access control, or audit infrastructure built for traditional software was designed with that kind of autonomy in mind.

Source: [NIST, "Announcing the 'AI Agent Standards Initiative' for Interoperable and Secure Innovation"](#)

NIST Rebrands Its Flagship AI Consortium — and Widens the Lens

In late May, NIST renamed the group formerly known as the AI Safety Institute Consortium to the NIST AI Consortium — a small naming change that signals a larger shift in emphasis, from AI safety narrowly defined to AI measurement, innovation, and adoption more broadly. Six new task groups now sit under the consortium, and NIST opened the door to new member organizations on a rolling basis.

The reframing matters less for what it removes and more for what it adds: adoption and measurement, sitting alongside safety, as co-equal priorities. It's a signal that the federal posture on AI is shifting from "how do we prevent harm" toward "how do we responsibly scale this everywhere" — which puts even more weight on organizations having a reliable, ongoing way to measure what they've actually deployed.

Source: [NIST, "NIST Expands AI Consortium's Scope, Calls for New Members"](#)

The Numbers Behind the Governance Gap

While standards bodies were busy publishing frameworks, Verizon's 2026 Data Breach Investigations Report quantified just how far ahead of policy actual employee behavior has run. Shadow AI — AI tools used without IT's knowledge or approval — showed up as the third most common non-malicious insider action detected across enterprise environments, a fourfold jump from the year before. Separately, a survey of 1,250 office professionals across four countries found that two-thirds had used an AI tool at work despite believing it went against company policy.

Put together, the pattern is consistent across nearly every independent data source tracking this in 2026: employees are adopting AI faster than IT departments are discovering it, and the discovery gap itself — not any single tool — has become the primary source of exposure. Most organizations aren't blind to AI use in the abstract. They're blind to which tools, used by whom, sending what data, right now.

Source: [Verizon 2026 Data Breach Investigations Report, as reported by Tech Times; PagerDuty, "Two-Thirds of Office Professionals Have Used Unauthorized AI Tools at Work"](#)

NIST Proves, Mathematically, That Static Defenses Aren't Enough

In June, NIST researcher Apostol Vassilev published a peer-reviewed proof in IEEE Security & Privacy that reframed the entire conversation about AI guardrails. Extending the logic of Kurt Gödel's century-old incompleteness theorems, Vassilev showed that no finite set of rules governing an AI system's behavior can ever be universally robust against adversarial prompts. There will always exist some prompt, in principle, that a fixed set of guardrails cannot catch — it's simply a matter of an adversary finding it.

The practical implication isn't that defense is futile — it's that defense built around a single point-in-time evaluation is the wrong model entirely. Vassilev's recommended posture has three parts: continuous red-teaming to find new weaknesses before attackers do, continuous updates to harden guardrails against what's found, and operational resilience that assumes an exploit will eventually succeed and prioritizes fast containment and recovery over prevention alone.

It's a rare thing: a mathematical, rather than merely observational, argument for why "we assessed our AI posture last quarter" is a fundamentally different — and weaker — claim than "we are continuously watching what our AI systems are doing right now."

Source: [NIST, "NIST Mathematical Proof Supports Transition to a Continuous-Monitor-and-Update Security Model for AI Systems"](#)

This page is updated as new governance, standards, and research developments emerge.